SEGURIDAD CORPORATIVA

Caso 01: 4Geeks

Análisis Forense, Pentesting y Plan de Respuesta

Grupo 3

Made with GAMMA

Contexto de Vulnerabilidades

Entendiendo las Amenazas

Exploramos dos vulnerabilidades comunes que pueden comprometer la seguridad de nuestros sistemas. Comprenderlas es el primer paso para proteger nuestra infraestructura digital.

FTP Anónimo

El Protocolo de Transferencia de Archivos (FTP) permite mover documentos entre ordenadores. Cuando se configura para acceso anónimo, no requiere usuario ni contraseña, abriendo una puerta a que cualquier persona pueda ver, descargar o incluso modificar archivos cruciales de nuestros servidores.

Credenciales Débiles MySQL

MySQL es un sistema esencial para gestionar bases de datos, donde se almacena información crítica. Utilizar contraseñas débiles o por defecto en MySQL facilita que atacantes las adivinen, obteniendo acceso total a datos sensibles y poniendo en riesgo la confidencialidad y la integridad de nuestra información.

Made with GAMMA

Pentesting

Evaluación de Vulnerabilidades

Identificación y análisis de puntos débiles en sistemas, redes y aplicaciones para fortalecer nuestra postura de seguridad.

FTP Anónimo

Exposición: Acceso sin autenticación al servidor FTP, permitiendo a usuarios no autorizados ver o modificar archivos críticos.

CRÍTICO

Solución: Deshabilitar el acceso anónimo y exigir autenticación con credenciales robustas para todas las conexiones FTP.

Credenciales Débiles MySQL

Exposición: Uso de contraseñas simples o por defecto en bases de datos MySQL, haciendo los sistemas vulnerables a ataques de fuerza bruta y acceso no autorizado.

CRÍTICO

Solución: Implementar políticas de contraseñas robustas, cambiar todas las credenciales por defecto y utilizar métodos de autenticación más seguros.

Made with GAMMA

Explotación

Impacto de Vulnerabilidades

Una vez identificadas, las vulnerabilidades pueden ser explotadas, causando daños significativos a la infraestructura y datos. Comprender estos impactos es crucial para priorizar y aplicar soluciones efectivas.

FTP Anónimo

Exposición: Descarga y modificación de archivos del servidor sin restricciones, llevando a la filtración o alteración de información crítica.

CRÍTICO

Solución: Implementar autenticación obligatoria y limitar permisos de escritura para asegurar la integridad y confidencialidad de los datos.

Credenciales Débiles MySQL

Exposición: Acceso no autorizado a bases de datos sensibles, resultando en robo de información, manipulación de datos y posible interrupción del servicio.

CRÍTICO

Solución: Usar contraseñas complejas, cambiar credenciales por defecto inmediatamente y limitar el acceso remoto para proteger la información confidencial.

Made with GAMMA

EVALUACIÓN DE VULNERABILIDADES

Pentesting - Evaluación de Configuraciones

Identificación de brechas en la gestión de privilegios y visibilidad del servidor para mitigar vectores de ataque internos.

Permisos Excesivos en Configuración

Exposición: Archivos críticos (como wp-config.php) con permisos 777, permitiendo a cualquier usuario del sistema leer, modificar o borrar credenciales de base de datos.

CRÍTICO

Solución: Aplicar el principio de menor privilegio, restringiendo archivos sensibles a permisos 600 (solo propietario).

Enumeración de Directorios Web

Exposición: Configuración de Apache que permite el listado automático de archivos, exponiendo la estructura interna y archivos sensibles a atacantes.

MEDIO / ALTO

Solución: Desactivar la directiva 'Indexes' en la configuración global de Apache para impedir el rastreo de directorios.

Made with GAMMA

⚠ ANÁLISIS DE IMPACTO

Explotación - Impacto en la Infraestructura

El aprovechamiento de configuraciones débiles permite la persistencia de amenazas y la exfiltración de información técnica.

Inyección y Persistencia (Permisos 777)

Exposición: La escritura universal permite a un atacante inyectar scripts maliciosos o malware que se ejecuta con privilegios del servidor web.

CRÍTICO

Solución: Ejecutar saneamiento masivo de directorios (755) y archivos (644) para bloquear la capacidad de escritura no autorizada.

Reconocimiento y Mapeo (Indexes)

Exposición: Navegación libre por la jerarquía del servidor, facilitando el descubrimiento de archivos de respaldo, logs o carpetas de administración.

CRÍTICO

Solución: Implementar respuestas de error '403 Forbidden' ante intentos de acceso a directorios sin archivo de índice.

Made with GAMMA

PLAN DE CONTINUIDAD

Garantía de Continuidad

Plan de Recuperación ante Desastres (DRP)

Para asegurar que nuestras operaciones se mantengan robustas frente a cualquier eventualidad, hemos diseñado un Plan de Recuperación ante Desastres (DRP) centrado en la velocidad y la mínima pérdida de datos. Este plan define nuestras prioridades de recuperación y mitigación.

Respaldo 3-2-1

Todos los datos críticos se almacenan en **tres ubicaciones** distintas, utilizando **dos formatos** diferentes, con al menos **una copia** fuera de la oficina. Esto asegura una protección robusta contra la pérdida total.

Tiempo de Recuperación (RTO)

En caso de una interrupción total del servicio, nuestro objetivo es restaurar la funcionalidad completa en un máximo de **4 horas**. Esto minimiza el impacto en nuestras operaciones y usuarios.

Punto de Recuperación (RPO)

Garantizamos que, ante cualquier incidente, la cantidad máxima de datos que podríamos perder corresponde a las últimas **24 horas**. Los respaldos se realizan continuamente para cumplir con este objetivo.

Made with GAMMA

→ PRÓXIMOS PASOS

Recomendaciones Estratégicas

Fortaleciendo la Postura de Seguridad Continuamente

Para garantizar una seguridad robusta y adaptativa, proponemos un plan de acción proactivo centrado en la revisión constante, la vigilancia activa y el fomento de una cultura de seguridad integral.

Auditorías Trimestrales

Realizar revisiones periódicas de puertos y permisos para identificar y corregir posibles vulnerabilidades antes de que sean explotadas. Esto asegura que solo los servicios necesarios estén expuestos y que los accesos estén correctamente limitados.

Monitorización Activa

Implementar sistemas de alerta temprana que notifiquen sobre intentos de acceso fallidos o patrones de comportamiento anómalos. La vigilancia constante permite una respuesta rápida ante cualquier indicio de actividad maliciosa.

Cultura de Seguridad

Capacitar continuamente a todo el personal en las mejores prácticas de seguridad, con énfasis en la creación y gestión de contraseñas robustas. Una fuerza laboral informada es nuestra primera línea de defensa contra las amenazas cibernéticas.

Made with GAMMA